

ПОЛИТИКА ЗАЩИТЫ ИНФОРМАЦИИ

1. Область действия политики

1.1. Настоящая Политика устанавливает единые требования и правила обеспечения защиты информации в ФинтехБанк (далее Банк).

1.2. Действие Политики распространяется на:

- Информационные системы (ИС): Основные банковские системы (АБС), работающие на собственных серверах Банка; сервисы для клиентов, функционирующие в частном облаке.
- Инфраструктуру: Штаб-квартиру, ИТ-хаб, центры обработки данных, а также сеть из 150 офисов, работающих в смешанном режиме (удаленно/офис).
- Информацию: Персональные данные клиентов (в соответствии с ФЗ-152), данные критической информационной инфраструктуры (в соответствии с ФЗ-187), информацию о финансовых операциях (в соответствии с ГОСТ Р 57580), а также коммерческую тайну и внутренние документы Банка.

2. Цели и задачи защиты информации

2.1. Главная цель: Обеспечение устойчивости бизнеса и сохранение доверия клиентов путем надежной защиты активов Банка от внутренних и внешних угроз.

2.2. Задачи:

- Предотвращение критических инцидентов, таких как захват компьютеров администраторов, DDoS-атаки на клиентские сервисы и утечки данных через инсайдеров.
- Минимизация финансовых рисков путем перевода оценки киберинцидентов в денежный эквивалент (через Комитет по рискам).
- Обеспечение круглосуточного контроля (24/7) за состоянием защищенности информационных ресурсов.

- Соблюдение требований законодательства РФ (ФЗ-152, ФЗ-187) и отраслевых стандартов (ГОСТ Р 57580).

3. Принципы защиты информации

Архитектура защиты Банка базируется на следующих фундаментальных принципах:

3.1. Принцип нулевого доверия: Мы никому не доверяем по умолчанию. Каждый запрос на доступ подвергается строгой проверке независимо от источника.

3.2. Принцип сегментации и разделения данных: Важные данные отделены друг от друга. Доступ к критическим активам изолирован.

3.3. Принцип эшелонированной защиты: Для доступа к ценной информации злоумышленнику необходимо преодолеть минимум три разные преграды. Если одна система защиты не работает, остальные остановят атаку.

3.4. Принцип независимости: Главный по безопасности подчиняется напрямую Совету директоров, что исключает возможность давления на решения по защите данных со стороны других подразделений.

4. Перечни объектов защиты

4.1. Программные и программно-аппаратные средства:

- Серверное оборудование АБС.
- Системы шифрования данных.
- Средства мониторинга и обнаружения вторжений

4.2. Информационные системы:

- АБС (на собственных серверах).
- Клиентские сервисы (в частном облаке).

4.3. Сети и подсети:

- Внутренняя корпоративная сеть, объединяющая 150 офисов и удаленные рабочие места сотрудников.
- Каналы связи между ЦОД, ИТ-хабом и штаб-квартирой.

5. Категории лиц, участвующих в защите информации

5.1. Совет директоров: Осуществляет стратегический контроль. Получает отчеты от Директора по информационной безопасности.

5.2. Директор по информационной безопасности:

- Несет персональную ответственность за состояние ИБ.
- Подчиняется напрямую Совету директоров.
- Утверждает меры по реагированию на инциденты.

5.3. Комитет по рискам:

- Оценивает киберинциденты в денежном эквиваленте.
- Определяет приоритеты защиты (критический, высокий, низкий уровень риска).

5.4. Сотрудники Центра безопасности:

- Осуществляют круглосуточный мониторинг.
- Включают аналитиков трех уровней подготовки для оперативного выявления и реагирования на угрозы.

5.5. Работники Банка:

- Обязаны соблюдать правила обработки информации и требования ИБ, особенно при работе в смешанном режиме (из дома/офиса).

6. Состав организационной системы управления и схема взаимодействия

6.1. Система управления ИБ построена по иерархическому принципу с прямой подотчетностью высшего уровня.

6.2. Схема взаимодействия:

- **Совет директоров и Директор по информационной безопасности:**
Стратегическое управление и контроль.
- **Директор по информационной безопасности и Комитет по рискам:**
Оценка угроз и утверждение бюджета на защиту.
- **Директор по информационной безопасности и Сотрудники Центра безопасности** (3 уровня аналитиков):
Оперативное управление инцидентами. Сотрудник Центра безопасности докладывает Директору по ИБ о критических событиях.
- **Директор по информационной безопасности <-> Владельцы бизнес-процессов:**
Внедрение ИБ в бизнес-процессы.

7. Ответственность работников

7.1. Работники Банка несут ответственность за нарушение требований настоящей Политики, а также за нарушение установленных Банком правил обработки информации.

7.2. В зависимости от характера нарушения и последствий, работники могут быть привлечены к:

- Дисциплинарной ответственности: (замечание, выговор, увольнение) за несоблюдение регламентов доступа, утерю пропусков, игнорирование предупреждений Сотрудника.
- Административной ответственности: в случаях, предусмотренных КоАП РФ (например, нарушение законодательства о персональных данных).
- Уголовной ответственности: в случаях, предусмотренных УК РФ (несанкционированный доступ, создание вредоносных программ, разглашение коммерческой тайны).

7.3. Особое внимание уделяется ответственности за инсайдерские угрозы, выявленные как приоритетные риски в оценке угроз Банка.

*Документ разработан в соответствии с Приказом ФСТЭК России №117 п.14
пп. А)*